# LAB 03: Threat & Risk Lab — Risk Register Raporu

**Ders:** Yazılım Mühendisliği Güncel Konular | **Çerçeve:** Safety 4.0, IEC 62443-3-2, ISO 12100 & EU Machinery Regulation (2023/1230) | **Tarih:** 24 Ekim 2026
|---|

## 1. Giriş ve Amaç

Bu rapor, **Safety 4.0 Readiness Bootcamp Lab 3** standartlarına ve **IEC 62443-3-2** metodolojisine uygun olarak hazırlanmıştır. Raporun temel amacı, **Otomatik Kenar Bantlama Makinesi Besleme Ünitesi (AIMSAD)** ve referans makine olan **Şişeleme Hattı** üzerindeki siber-fiziksel tehditleri belirlemek, bu tehditlerin emniyet fonksiyonlarına etkisini analiz etmek ve $L \times S \times E$ matrisi ile risk puanlamalarını gerçekleştirerek önceliklendirilmiş bir Risk Register (Risk Sicili) oluşturmaktır.

## 2. Metodoloji ve Puanlama Çerçevesi

Tehdit senaryoları 5 temel bileşenden oluşmaktadır:

- **Profil (Kim?):** Meraklı İçeriden, Fırsatçı Dış, Hedefli Saldırgan, Tedarik Zinciri.
- **Giriş (Hangi Kapı?):** Uzak bakım modülü, HMI, açık Ethernet portları, imzasız güncellemeler vb.
- **Eylem (Ne Yapar?):** Parametre değiştirme, program yükleme, bypass/force, sahte veri gönderme.
- **Zincir (Nasıl İlerler?):** İlk erişimden emniyet kontrolcüsüne yanal hareket.
- **Sonuç (Fiziksel Etki):** ISO 12100 standartlarında tanımlanmış mekanik, termal veya fiziksel yaralanma.

### Risk Hesaplama Formülü

$$\text{Risk Skoru} = L \times S \times E$$

| Parametre | Derece 1 | Derece 2 | Derece 3 |
|---|---|---|---|
| **L (Likelihood / İstismar Edilebilirlik)** | 1 — Zor | 2 — Orta | 3 — Kolay |
| **S (Safety Impact / Fiziksel Şiddet)** | 1 — Yaralanma Yok | 2 — Hafif Yaralanma | 3 — Ağır / Kalıcı Yaralanma, Ölüm |

| Parametre | Derece 1 | Derece 2 | Derece 3 |
|---|---|---|---|
| **E (Exposure / Dışa Açıklık)** | 1 — Kapalı / Yerel | 2 — Sınırlı / Fabrika Ağı | 3 — Açık / İnternet |

**S3 Kuralı:** $S = 3$ (Ağır yaralanma veya hayati risk) olan her senaryo, çarpım skoru ne olursa olsun S3 Bayrağı alır; üst yönetime raporlanır ve yazılı kabul kararı/önlem olmadan kapatılamaz.

## 3. Otomatik Kenar Bantlama Makinesi Besleme Ünitesi — Risk Register

| Risk ID | Senaryo Özeti | L | S | E | Skor | S3 | Mevcut Durum | Önerilen Önlem | Sorumlu |
|---|---|---|---|---|---|---|---|---|---|
| **R-01** | **Uzak Bakım Modülü Üzerinden Işık Perdesi Manipülasyonu**Fırsatçı dış saldırgan, internete açık uzak bakım modülü üzerinden içeri girer ve Safety PLC'deki ışık perdesi tepki parametresini değiştirir; durdurma süresi uzayarak el koruma fonksiyonu (SF-01) bozulur ve operatörün parmağı panel besleme çenesine sıkışır. | 3 | 3 | 3 | **27***(Kritik)* | EVET | Şifresiz/doğrudan erişimli uzak bakım modülü. | Uzak erişimde VPN + Çok Faktörlü Kimlik Doğrulama (MFA) zorunluluğu, modülün yalnızca bakım anında aktif edilmesi. | OT Otomasyon Lideri *(RACI: A)* |
| **R-02** | **Paylaşılan HMI Hesabı Üzerinden Hız Limiti Aşımı**Meraklı içeriden çalışan, paylaşılan HMI servis hesabı üzerinden HMI reçete/hız ekranında yetkisiz değişiklik yapar; ön frezeleme ünitesi hız limitleri aşılarak parça fırlaması yaşanır ve operatör yüzünden yaralanır. | 2 | 3 | 2 | **12***(Yüksek)* | EVET | Ortak varsayılan admin parolası. | Role dayalı erişim kontrolü (RBAC) ve her operatör/teknisyen için bireysel kimlik doğrulama. | MES / SCADA Sorumlusu *(RACI: A)* |
| **R-03** | **İmzasız Yazılım/Firmware ile Safety Interlock Bypass**Tedarik zinciri saldırganı, imzasız servis bilgisayarı veya güncelleme | 1 | 3 | 1 | **3***(Düşük)* | EVET | Servis güncellemelerinde imza doğrulaması yok. | PLC düzeyinde kriptografik olarak imzalı firmware zorunluluğu ve fiziksel anahtarlı Lockout/Tagout (LOTO) prosedürleri. | Bakım Şefi *(RACI: A)* |

| Risk ID | Senaryo Özeti | L | S | E | Skor | S3 | Mevcut Durum | Önerilen Önlem | Sorumlu |
|---|---|---|---|---|---|---|---|---|---|
| | kanalıyla Safety PLC mantığını bypass eder; interlock kilitleme devredışı kalır ve bakım kapısı açıkken bıçak bölgesine erişildiğinde kesilme kazası oluşur. | | | | | | | | |

### 4. Şişeleme Hattı (Referans Makine) — Risk Register

| Risk ID | Senaryo Özeti | L | S | E | Skor | S3 | Mevcut Durum | Önerilen Önlem | Sorumlu |
|---|---|---|---|---|---|---|---|---|---|
| R-04 | **DMZ / HMI Üzerinden Dolum Karuseli Basınç Manipülasyonu**Fırsatçı dış saldırgan, DMZ üzerindeki açık port/HMI arayüzünden dolum karuseli hız/basınç set değerini manipüle eder; cam şişe patlama eşiği aşılarak cam fırlamasıyla operatör yaralanır (SF: Kapaklama Koruma Kilidi). | 3 | 3 | 2 | 18*(Kritik)* | EVET | IT ve OT ağları arasında zayıf firewall kural yapılandırması. | Katı Zone & Conduit segmentasyonu, Derin Paket İnceleme (DPI) yapabilen endüstriyel güvenlik duvarı. | IT/OT Güvenlik Sorumlusu *(RACI: A)* |
| R-05 | **Robot Paletleyici Teach Pendant Üzerinden Muting Bypass**Meraklı içeriden çalışan, teach pendant portundan erişip alan tarayıcı muting/bypass durumunu açık bırakır; robot alanına giren operatör algılanmaz ve robot kolunun çarpması sonucu ezilme yaşanır. | 2 | 3 | 1 | 6*(Orta)* | EVET | Teach pendant kabini kilitsiz. | Fiziksel kilitli kılıf, anahtarlı mod seçici anahtar ve otomatik zaman aşımı prosedürü. | Emniyet Mühendisi *(RACI: A)* |

### 5. Sonuç ve Gelecek Adımlar (LAB 4 Bağlantısı)

Risk Register analizi sonucunda, siber zafiyetlerin doğrudan fiziksel emniyet fonksiyonlarını bozabileceği kanıtlanmıştır. Önlemler uygulandığında $L$ (istismar edilebilirlik) ve $E$ (dışa açıklık) değerleri düşürülebilse de, $S$ (şiddet) parametresi ancak emniyet mimarisinin fiziksel/bağımsız tasarımıyla değiştirilebilir.

Bir sonraki aşamada (LAB 4), en yüksek skorlu senaryolar Güvenli Mimariler (Secure Architecture) vasıtasıyla tasarımsal olarak kırılacaktır.